

SYS.1.2.4 Windows Server 2022

1 Beschreibung

1.1 Einleitung

Windows Server 2022 ist ein Server-Betriebssystem im Long-Term Servicing Channel (LTSC). Es bietet gegenüber Vorgängerversionen erweiterte integrierte Sicherheitsfunktionen, die auf den Schutz vor modernen Bedrohungen auf Hardware-, Firmware- und Netzwerkebene abzielen. Zu den Kernkomponenten gehören die "Secured-core"-Architektur zum Schutz der Systemintegrität, die standardmäßige Integration von TLS 1.3 zur Härtung der Transportverschlüsselung sowie die native Unterstützung von DNS-over-HTTPS (DoH).

1.2 Zielsetzung

Der Baustein beschreibt die Anforderungen für die sichere Planung, Installation, Konfiguration und den Betrieb von Windows Server 2022. Ziel ist es, die spezifischen Sicherheitsfunktionen des Betriebssystems herstellergerecht zu implementieren, die Angriffsfläche zu minimieren und die Aspekte der Vertraulichkeit, Integrität und Verfügbarkeit ganzheitlich zu gewährleisten.

1.3 Abgrenzung und Modellierung

Der Baustein SYS.1.2.4 ist auf alle IT-Systeme anzuwenden, auf denen Windows Server 2022 in den Editionen Standard oder Datacenter installiert ist.

Dieser Baustein ersetzt nicht die allgemeinen Anforderungen aus dem Baustein SYS.1.1 *Allgemeiner Server*, sondern ergänzt und konkretisiert diese versionsspezifisch. Bei der Nutzung von Verzeichnisdiensten ist zusätzlich der Baustein APP.2.2 *Active Directory Domain Services* anzuwenden. Werden Cloud-Dienste oder Hybrid-Szenarien genutzt, sind ergänzend die Anforderungen des Bausteins OPS.2.2 *Cloud-Nutzung* zu berücksichtigen.

2 Gefährdungslage

Für Systeme mit Windows Server 2022 sind folgende spezifische Gefährdungen von besonderer Bedeutung.

Ausnutzung von Schwachstellen in neuen oder komplexen Diensten

Neue und erweiterte Funktionen, wie die tiefe Integration in cloudbasierte Management-Dienste oder das webbasierte Administration Center, schaffen neue Angriffsflächen. Werden diese Dienste fehlerhaft konfiguriert, können sie als Einfallstor für Angreifer dienen.

Kompromittierung durch unsichere Hybrid-Cloud-Anbindungen

Die Anbindung an Cloud-Dienste kann zu einer unerwünschten Vermischung von

Sicherheitsdomänen führen. Eine kompromittierte Cloud-Identität kann missbraucht werden, um auf On-Premises-Ressourcen zuzugreifen, oder ein lokaler Server kann als Sprungbrett in die Cloud dienen.

Umgehung von Sicherheitsmechanismen durch veraltete Konfigurationen

Werden bestehende Konfigurationsskripte oder Gruppenrichtlinien von älteren Server-Versionen unverändert auf Windows Server 2022 übernommen, werden essenzielle neue Sicherheitsfunktionen unter Umständen nicht aktiviert. Das System bleibt dadurch anfällig für Angriffe, die durch moderne Mechanismen verhindert werden könnten.

Angriffe auf die Firmware- und Boot-Ebene

Trotz der in das Betriebssystem integrierten Secured-core-Architektur bleibt das System anfällig für Angriffe unterhalb der Betriebssystemebene (z. B. Boot- oder Rootkits), wenn diese Funktionen aufgrund fehlender Hardware-Kompatibilität oder falscher Konfiguration nicht wirksam geschützt sind.

Abhören oder Manipulation der Netzwerkkommunikation

Zwar unterstützt das System moderne Protokolle, jedoch können veraltete Anwendungen oder fehlerhafte Konfigurationen ein Downgrade auf unsichere Verschlüsselungsprotokolle erzwingen. Zudem bleibt die Namensauflösung ohne aktive Konfiguration verschlüsselter DNS-Protokolle anfällig für Ausspähung und Manipulation durch Man-in-the-Middle-Angriffe.

3 Anforderungen

Im Folgenden sind die spezifischen Anforderungen des Bausteins SYS.1.2.4 aufgeführt. Grundsätzlich ist der IT-Betrieb für die Erfüllung der Anforderungen zuständig. Abweichungen werden in den entsprechenden Anforderungen gesondert genannt.

Zuständigkeiten	Rollen
Grundsätzlich zuständig	IT-Betrieb
Weitere Zuständigkeiten	Informationssicherheitsbeauftragter (ISB), Planer

3.1 Basis-Anforderungen

Die folgenden Anforderungen MÜSSEN vorrangig erfüllt werden.

SYS.1.2.4.A1 Planung des Einsatzes von Windows Server 2022 (B)

[Planer]

Im Vorfeld der Installation MUSS geplant werden, welche Serverrollen und Features für den vorgesehenen Einsatzzweck zwingend benötigt werden. Es MUSS geprüft werden, ob die zugrundeliegende Hardware die spezifischen Sicherheitsfunktionen des Betriebssystems unterstützt.

SYS.1.2.4.A2 Gesicherte Installation und initiale Konfiguration (B)

Die Installation von Windows Server 2022 MUSS von einem vertrauenswürdigen und auf Integrität geprüften Installationsmedium erfolgen. Nach der Installation MUSS das standardmäßige lokale Administratorkonto umbenannt und mit einem sicheren Passwort versehen werden.

SYS.1.2.4.A3 Grundlegende Härtung des Betriebssystems (B)

Nicht benötigte Serverrollen, Features und Dienste MÜSSEN deinstalliert oder deaktiviert werden. Die systemeigene hostbasierte Firewall MUSS aktiviert sein und mit einer restriktiven, an den Einsatzzweck angepassten Regelbasis betrieben werden.

SYS.1.2.4.A4 Absicherung der Benutzerkonten und Privilegien (B)

Die Benutzerkontensteuerung (User Account Control, UAC) MUSS aktiviert sein. Administrative Berechtigungen DÜRFEN nur an einen eng begrenzten und dokumentierten Kreis von Administratoren vergeben werden.

SYS.1.2.4.A5 Aktivierung der grundlegenden Protokollierung (B)

Die Protokollierung sicherheitsrelevanter Ereignisse (wie An- und Abmeldungen, Änderungen an Konten und Gruppenrichtlinien) MUSS im Betriebssystem aktiviert sein. Es MUSS sichergestellt werden, dass die lokalen Ereignisprotokolle vor unbefugter Manipulation oder Löschung geschützt sind.

SYS.1.2.4.A6 Regelmäßiges Patch-Management (B)

Es MUSS ein Prozess etabliert sein, der sicherstellt, dass bereitgestellte Sicherheitsupdates für das Betriebssystem und installierte Komponenten regelmäßig und zeitnah eingespielt werden.

3.2 Standard-Anforderungen

Gemeinsam mit den Basis-Anforderungen entsprechen die folgenden Anforderungen dem Stand der Technik bei normalem Schutzbedarf. Sie SOLLTEN grundsätzlich erfüllt werden.

SYS.1.2.4.A7 Nutzung der Secured-core Server-Funktionen (S)

Auf unterstützter Hardware SOLLTEN die Secured-core-Funktionen aktiviert werden. Dies umfasst die Virtualisierungsbasierte Sicherheit (VBS), die Hypervisor-geschützte

Codeintegrität (HVCI) und den Schutz vor DMA-Angriffen beim Startvorgang.

SYS.1.2.4.A8 Konsequente Nutzung von Transportverschlüsselung (S)

Die systemweite Verwendung von TLS 1.3 SOLLTE konfiguriert werden. Ältere und als unsicher eingestufte Protokolle, insbesondere SSL sowie TLS 1.0 und TLS 1.1, SOLLTEN systemweit deaktiviert werden. Für den Zugriff auf Dateifreigaben SOLLTE die SMB-Verschlüsselung aktiviert werden.

SYS.1.2.4.A9 Härtung der Remote-Verwaltung (S)

Der administrative Fernzugriff auf den Server SOLLTE ausschließlich über authentifizierte und verschlüsselte Protokolle erfolgen (z. B. PowerShell Remoting über HTTPS oder SSH). RDP-Zugriffe SOLLTEN auf ein Minimum beschränkt und netzwerktechnisch abgesichert werden. Wird ein webbasiertes Administrationswerkzeug genutzt, SOLLTE dieses gehärtet und der Zugriff darauf stark authentisiert werden.

SYS.1.2.4.A10 Implementierung von Credential Guard (S)

Auf Systemen, die die Hardware-Voraussetzungen erfüllen, SOLLTE der Schutz für zwischengespeicherte Anmeldeinformationen (Credential Guard) aktiviert werden.

SYS.1.2.4.A11 Absicherung der DNS-Kommunikation (S)

Der lokale DNS-Client SOLLTE so konfiguriert werden, dass er für die Auflösung von Namen DNS-over-HTTPS (DoH) verwendet, sofern die Infrastruktur dies unterstützt.

3.3 Anforderungen bei erhöhtem Schutzbedarf

Die folgenden Anforderungen sind exemplarisch und bei erhöhtem Schutzbedarf zu berücksichtigen; die konkrete Festlegung erfolgt im Rahmen einer Risikoanalyse. Der Schutzziel-Bezug ist am Ende jeder Anforderung in Klammern angegeben (C = Vertraulichkeit, I = Integrität, A = Verfügbarkeit).

SYS.1.2.4.A12 Implementierung von Application Control (H)

Es SOLLTE eine Positivliste von zulässigen Anwendungen (Application Control) durchgesetzt werden. Es SOLLTE sichergestellt werden, dass nur signierter und explizit vertrauenswürdiger Code auf dem Server ausgeführt werden kann. (I)

SYS.1.2.4.A13 Sichere Anbindung an Hybrid-Dienste (H)

Wird der Server mittels cloudbasierter Management-Lösungen verwaltet, SOLLTE der Onboarding-Prozess kryptografisch abgesichert und der administrative Zugriff aus der Cloud streng kontrolliert und überwacht werden. Sicherheitsrichtlinien SOLLTEN zentral durchgesetzt werden. (C, I)

SYS.1.2.4.A14 Umfassende Protokollierung und Detektion (H)

Es SOLLTE eine erweiterte Systemprotokollierung aktiviert werden, die Skript-Ausführungen und die Erstellung von Prozessen detailliert erfasst. Diese Daten SOLLTEN an ein zentrales System (z. B. SIEM) weitergeleitet und durch eine EDR-Lösung (Endpoint Detection and Response) kontinuierlich auf Anomalien überwacht werden. (I, A)

SYS.1.2.4.A15 Einsatz von Just-In-Time und Just-Enough-Administration (H)

Administrative Berechtigungen SOLLTEN nur bei Bedarf und zeitlich begrenzt vergeben werden (Just-In-Time). Für Routineaufgaben SOLLTEN administrative Endpunkte so konfiguriert werden, dass Administratoren nur die Ausführung fest definierter und zwingend benötigter Befehle erlaubt ist (Just-Enough-Administration). (C, I)

SYS.1.2.4.A16 Härtung des SMB-Protokolls über nicht vertrauenswürdige Netze (H)

Für den Zugriff auf Dateifreigaben von außerhalb vertrauenswürdiger Netzwerksegmente SOLLTE der Einsatz von SMB over QUIC konfiguriert werden. (C, I)

4 Weiterführende Informationen

4.1 Wissenswertes

Das BSI hat zur sicheren Konfiguration kryptografischer Verfahren die Technische Richtlinie TR-02102-2 "Kryptographische Verfahren: Verwendung von Transport Layer Security (TLS)" veröffentlicht.

Der Hersteller stellt in regelmäßigen Abständen "Security Baselines" zur Verfügung. Diese enthalten detaillierte Empfehlungen und Gruppenrichtlinien-Vorlagen zur Härtung von Windows Server 2022 und sollten beim Entwurf von Systemkonfigurationen berücksichtigt werden.

Kreuzreferenztafel zu elementaren Gefährdungen

Die folgenden elementaren Gefährdungen sind für den Baustein SYS.1.2.4 von Bedeutung:

- G 0.14 Ausspähen von Informationen (Spionage)
- G 0.15 Abhören
- G 0.18 Fehlplanung oder fehlende Anpassung
- G 0.21 Manipulation von Hard- oder Software
- G 0.22 Manipulation von Informationen
- G 0.23 Unbefugtes Eindringen in IT-Systeme
- G 0.28 Software-Schwachstellen oder -Fehler

- G 0.30 Unberechtigte Nutzung oder Administration von Geräten und Systemen

Anforderung	G 0.14	G 0.15	G 0.18	G 0.21	G 0.22	G 0.23	G 0.28	G 0.30
SYS.1.2 .4.A1 (B)			X					
SYS.1.2 .4.A2 (B)				X		X		X
SYS.1.2 .4.A3 (B)						X	X	
SYS.1.2 .4.A4 (B)	X				X			X
SYS.1.2 .4.A5 (B)				X	X			X
SYS.1.2 .4.A6 (B)						X	X	
SYS.1.2 .4.A7 (S)				X		X	X	
SYS.1.2 .4.A8 (S)	X	X			X			
SYS.1.2 .4.A9 (S)		X				X		X
SYS.1.2 .4.A10	X					X		X

(S)								
SYS.1.2 .4.A11 (S)	X	X			X			
SYS.1.2 .4.A12 (H)				X		X	X	
SYS.1.2 .4.A13 (H)	X			X	X	X		X
SYS.1.2 .4.A14 (H)					X	X		X
SYS.1.2 .4.A15 (H)				X	X	X		X
SYS.1.2 .4.A16 (H)	X	X			X			